

LF DECENTRALIZED TRUST · TECHNICAL ADVISORY COUNCIL

CRA readiness for LFDT projects

A proposal for SBOM publishing and support policies
as criteria for Graduated projects

Hendrik Ebbers

The CRA clock is already running

11 Sep 2026

Manufacturers must report actively exploited vulnerabilities and severe incidents via the ENISA Single Reporting Platform.

11 Dec 2027

Full CRA application. Manufacturers need SBOMs for their products. Steward reporting duties under Art. 24(3) apply.

Art. 24

Stewards must document a cybersecurity policy, handle vulnerabilities and cooperate with market surveillance authorities.

Manufacturers building on LFDT projects will ask us for composition, support and vulnerability information. Our graduation criteria should make sure that information exists.

Two SBOM formats, both widely supported

SPDX

Linux Foundation project, strong in license compliance.
SPDX 3.0 adds security profiles and a supportLevel field.

CycloneDX

OWASP project, strong in security use cases. VEX and attestations are part of the ecosystem.

OpenSSF already provides first building blocks

Resource	What it gives us
OSPS Baseline	Three maturity levels. SBOM required at Level 3 (OSPS-QA-02.02). Mapped to the CRA.
OpenSSF Scorecard	The automated checks our graduation criteria already use.
Best Practices Badge	Self-certification, now also for the Baseline levels.
Security Insights	Machine-readable security metadata, incl. a CRA steward field.
LF CRA Stewards Playbook	What stewards must do, and what they should not do.

FINOS already requires OSPS Baseline Level 3 for its Graduated stage, measured via LFX Insights.

OSPS = Open Source Project Security (OpenSSF)

Existing checks only test that an SBOM exists

Scorecard “SBOM” check

Experimental, only with SCORECARD_EXPERIMENTAL set. 5 points if any SBOM exists, 5 points if it is published as a release artifact. Format, version and content are not checked.

CLOMonitor (LFX Insights)

Passes if a release asset name contains “sbom” or the README has an SBOM section. Nothing beyond the file name is inspected.

We can use Scorecard for the **existence** check, but we need a separate **quality** bar on top.

BSI TR-03183-2 v2.1 defines a concrete quality bar

Format

CycloneDX $\geq$ 1.6 or SPDX $\geq$ 3.0.1,
serialised as JSON or XML.

One per version

A separate SBOM for every version
of a product.

No vulnerability data

An SBOM describes fixed
composition. Vulnerability status
belongs in VEX or CSAF.

BSI sees the guideline as interim until harmonised EU standards exist. It is still the most concrete SBOM profile for the CRA today.
[BSI TR-03183-2 v2.1.0 \(PDF\)](#).

What an SBOM must contain to be useful

Field	Why it matters
Supplier and SBOM author	Who made the component, who made the SBOM
Component name and version	Exact identification of what ships
Unique identifier (PURL)	Matching against vulnerability databases
Dependency relationships	Transitive exposure analysis
License (SPDX identifier)	License compliance downstream
Cryptographic hashes	Integrity of executable components
Timestamp	When the SBOM was produced

An SBOM answers one question. Enterprises have five.

What is inside?

SBOM

Is it affected?

**Advisories and
VEX**

How long will it
be fixed?

**Support and
EOL policy**

Is it authentic?

**Signing and
provenance**

Where do I find
it all?

**Security
Insights**

Where LFDT stands today

Already in place

- Scorecard-based criteria with MUST and SHOULD
- Downgrade path in the annual review

Gaps

- SBOM listed as artifact, but no project duty
- LTS strategy only recommended
- No machine-readable security metadata

Six building blocks we can adopt

Building block	Source	Covers
SBOM publishing	OSPS-QA-02.02	Composition per release
TR-03183-2 v2.1	BSI	SBOM quality
OSPS-QA-04.01 / 04.02	OSPS Baseline	Multi-repo projects
SUPPORT.md	OSPS-DO-04.01 / 05.01	Support and EOL
security-insights.yml	OpenSSF	Discovery, steward, status
OpenEoX	OASIS (draft)	Machine-readable lifecycle

SBOM publishing (OSPS-QA-02.02): baseline.openssf.org/versions/2026-08-28.html#osps-qa-0202

BSI TR-03183-2 v2.1: bsi.bund.de/.../TR03183/BSI-TR-03183-2_v2_1_0.pdf

OSPS-QA-04.01 / 04.02: baseline.openssf.org/versions/2026-08-28.html#osps-qa-0401

SUPPORT.md (OSPS-DO-04.01 / 05.01): baseline.openssf.org/versions/2026-08-28.html#osps-do-0401

security-insights.yml: github.com/ossf/security-insights-spec

OpenEoX: oasis-open.org/tc-openeox

SBOM publishing: what “published” means

1

Generated in CI

At build time by a vetted tool, never written by hand.

2

One per artifact

Published next to it: registry sibling or release asset.

3

Signed, immutable

Covered by the Sigstore release signature, never changed after release.

4

Format by choice

CycloneDX or SPDX, as the project prefers.

The Apache Software Foundation uses the same principles: signed with the release keys, static per release, machine-readable.

Three OSPS controls cover umbrella projects

QA-02.02 · Level 3

Every compiled released asset is delivered with an SBOM.

QA-04.01 · Level 1

Multi-repo projects document their codebases, incl. status and intent.

QA-04.02 · Level 3

Subprojects in a release are held to requirements as strict as the primary codebase.

Together they replace a percentage rule: every released component is in scope, and the inventory shows what is not.

SUPPORT.md: transparency, not a minimum duration

Four questions to answer

- Which versions get security fixes?
- For how long?
- What kind of fixes?
- How is end of life announced?

Common models

- LTS with overlap (Fabric)
- Time-based LTS
- Last N minor versions
- Fix-forward, latest only

OSPS-DO-04.01 and DO-05.01 require a **statement** about support scope and EOL, not a minimum period. The statement may even be that no support is provided. What matters is that it is documented.

security-insights.yml makes it discoverable

Parent file · per project

project.steward
documentation.support-policy
repositories
vulnerability-reporting



Child file · per repository

header.project-si-source
repository.status
release.distribution-points
release.attestations

OpenSSF Security Insights spec v2.2.0 (github.com/ossf/security-insights-spec). The steward field refers explicitly to the CRA definition. Repository status doubles as the machine-readable component inventory.

OpenEoX is the target format for lifecycle data

What it is

OASIS standard for GA, end of life and end of security support. Designed to complement SBOM, VEX and CSAF.

Status

Core Schema v1.0 draft (CSD01) in public review since July 2026. Not ratified yet.

Our transition

Projects keep one YAML source that generates SUPPORT.md now and OpenEoX later.

Scope: every released artifact of a GA component

“Every published artifact of a component with version $\geq 1.0.0$, or marked GA or LTS per the release taxonomy, meets the SBOM and support requirements from its next release on.”

Why not a percentage?

An enterprise using the one SDK without SBOM gains nothing from 75% coverage elsewhere. Quotas can be gamed by repo layout.

Criteria: SBOM

Level	Requirement
MUST	One SBOM per released artifact, CI-generated, published alongside, signed, immutable
MUST	Minimum fields: supplier, name, version, PURL, dependencies, license, author, timestamp, hashes
MUST	OpenSSF Scorecard “SBOM” check = 10
SHOULD → MUST	BSI TR-03183-2 v2.1 conformance, MUST after 12 months
SHOULD	sbomqs score ≥ [threshold after pilot]
Incubation · SHOULD	SBOM exists, Scorecard “SBOM” ≥ 5

Criteria: support policy and metadata

Level	Requirement
MUST	SUPPORT.md with supported versions, fix types and EOL rule, per released component
MUST	Unsupported versions are identified as EOL; a general rule is enough (e.g. “all but the latest”)
MUST, if fix-forward	Prompt security patch releases and SemVer within a major version
SHOULD → MUST	Lifecycle data in an OpenEoX-exportable YAML file; OpenEoX 12 months after ratification
SHOULD	Security fixes on maintained branches; EOL announced ≥ 6 months ahead
SHOULD → MUST	security-insights.yml, parent and child files
Incubation · SHOULD	State which version currently receives security fixes

Timeline

Q4 2026	1 Jan 2027	Mid 2027	11 Dec 2027	Later
TAC review, pilot with Besu, Fabric and Hiero to calibrate thresholds	Criteria apply to all new graduations	Mid-year updates report progress of existing projects	Existing Graduated projects comply, in line with full CRA application	All SHOULD → MUST criteria become MUST after 12 months; OpenEoX 12 months after ratification

Enforcement uses what we already have: the annual review and, where needed, a move back to Incubation.

What we require, and what we deliberately do not

We require

- SBOM per artifact, minimum content
- Generated in CI, published, signed
- Documented, honest support policy
- Machine-readable discovery

As steward, we do not

- Pick SPDX or CycloneDX
- Pick the generator tool
- Set a support duration or mandate LTS
- Attest “CRA compliance”

Next steps

1

TAC feedback

Discuss today, collect open questions.

2

Pilot

One or more pilot projects, calibrate sbomqs threshold.

3

Governance PR

Lifecycle criteria, incubation exit, SAMPLE-SUPPORT.md.

REFERENCES

Sources

OSPS Baseline (2026-08-28)

`baseline.openssf.org/versions/2026-08-28.html`

LF CRA Stewards Playbook

`policy.openssf.org/CRA/stewards-playbook.html`

BSI TR-03183-2 v2.1.0

`bsi.bund.de · TR-03183-2`

Scorecard checks

`github.com/ossf/scorecard/blob/main/docs/checks.md`

CLOMonitor checks

`github.com/cncf/clomonitor/blob/main/docs/checks.md`

Security Insights spec

`github.com/ossf/security-insights-spec`

OpenEoX TC

`oasis-open.org/tc-openeox`

Fabric LTS RFC

`github.com/hyperledger/fabric-rfcs · 0005`